Microsoft Purview FINRA/SEC Compliance Program

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — Microsoft Purview FINRA/SEC Compliance Program 5

The problem . . . 5

The solution . . . 5

What you get . . . 5

Approach . . . 5

Boundaries . . . 6

The bottom line . . . 6

1. Solution Overview — Microsoft Purview FINRA/SEC Compliance Program 6

What this solution is . . . 6

Why this matters . . . 6

How it works . . . 7

The control stack this solution configures . . . 7

What you can control . . . 8

Limitations (be honest with buyers) . . . 8

Naming convention (used in every doc and script) . . . 8

The standard deployment model . . . 9

2. Requirements Guide — Microsoft Purview FINRA/SEC Compliance Program 9

2.1 Compliance licensing for records, supervision, and audit evidence . . . 10

2.2 Least-privilege roles with reviewer separation . . . 10

2.3 Security & Compliance PowerShell + Graph toolchain . . . 10

2.4 In-scope population, workloads, and communications channels . . . 10

2.5 The rule-to-control map and retention schedule (from compliance/records/legal) . . . 11

2.6 Communication Compliance privacy & governance preconditions . . . 11

2.7 Unified audit logging on, and an evidence-retention requirement . . . 11

2.8 A pilot scope, simulation/test mode, and change control . . . 11

Global Requirements — Microsoft Purview Solutions 12

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 12

2. Purview roles (least-privilege) and portal access . . . 12

3. Security & Compliance PowerShell + Graph toolchain . . . 12

4. Data sources & scope in scope . . . 13

5. Compliance, records, privacy & legal stakeholders . . . 13

6. A pilot scope and change control . . . 13

3. Implementation Guide — Microsoft Purview FINRA/SEC Compliance Program 14

Step 1 — Assess current controls and licensing (Assess) . . . 14

Step 2 — Design the rule-to-control map (Design) . . . 15

Step 3 — Configure the records-preservation control (Configure → Pilot) . . . 15
Step 4 — Configure the audit-evidence control (Configure) . . . 15
Step 5 — Configure the communication-supervision control — IN TEST MODE (Configure → Pilot) 16
Step 6 — Track the program in Compliance Manager (Configure, in-portal) . . . 16
Step 7 — Validate the controls and generate evidence (Validate) . . . 16
Step 8 — Expand to enforcement and operationalize (Expand) . . . 17
5. Testing & Validation — Microsoft Purview FINRA/SEC Compliance Program 17
Gate 1 — Compliance licensing present for each control . . . 17
Gate 2 — Records label applies and preserves (pilot, non-regulatory first) . . . 17
Gate 3 — Regulatory-records behavior confirmed (post sign-off) . . . 18
Gate 4 — Communications-store retention scoped . . . 18
Gate 5 — Unified audit on and evidence policy present . . . 18
Gate 6 — Supervision policy exists in TEST with reviewer separation . . . 18
Gate 7 — Supervision surfaces test items (benign) . . . 19
Gate 8 — Control map and evidence binder generated . . . 19
Gate 9 — Validation scorecard is green (pilot) . . . 19
Evidence to retain . . . 19
6. Troubleshooting — Microsoft Purview FINRA/SEC Compliance Program 19
A capability is missing entirely (label type, supervision, audit tier) — likely a licensing gap . . . 20
`Connect-IPPSSession` fails or cmdlets are "not recognized" . . . 20
`Get-SupervisoryReviewPolicyV2` (or the supervision cmdlets) error / not found . . . 20
Records/regulatory-records label applied but content can still be deleted, or label isn't visible . . . 20
"I need to undo a regulatory-records label" — you can't . . . 21
Comms-store retention policy exists but Validate shows it DISABLED or out of scope . . . 21
Audit gate red: ingestion off, or evidence policy missing . . . 21
Supervision policy created but no review items appear . . . 21
Reviewers can see too much, or the configuring admin can self-review . . . 22
Graph licensing or population check fails . . . 22
Evidence binder has gaps (a control with no proof) . . . 22
A `-Commit` change didn't take effect . . . 22
Everything passes for the pilot but you're unsure you're "FINRA/SEC-ready" . . . 22
7. Best Practices — A Defensible FINRA/SEC Program on Microsoft Purview 23
Stay in your lane: configure the control, defer the determination . . . 23
Treat regulatory records as one-way doors . . . 23
Records preservation is (mostly) not retroactive . . . 23
Build supervision privacy-first, and separate the roles . . . 23

Make evidence a first-class deliverable . . . 24
Audit is the evidence layer — keep it on and retained . . . 24
Least-privilege everywhere, reviewed periodically . . . 24
Pilot every change, keep a rollback (except where you can't) . . . 24
Operate it as a program, not a project . . . 24
8. Deliverables Summary — Microsoft Purview FINRA/SEC Compliance Program 24
Documentation . . . 25
PowerShell tools (5) . . . 25
Named artifacts created . . . 27
Definition of done . . . 27
Appendix A — PowerShell Scripts 28

Executive Summary — Microsoft Purview FINRA/SEC Compliance Program

The problem

For a regulated broker-dealer or investment adviser, an examination comes down to two demands: *"show me the control"* and *"show me the evidence."* FINRA and SEC obligations — supervision of electronic communications, books-and-records preservation, and a defensible audit trail — too often exist as policy on paper with no mapped technical control behind them and no evidence that can be produced on demand. Left unaddressed, that is both a compliance gap and a data-risk exposure, and it surfaces at the worst possible moment: mid-exam.

The solution

A complete, self-guided FINRA/SEC **control-and-evidence program** built on **Microsoft Purview**. It maps the in-scope obligations to three configured Purview controls — **records/regulatory-records retention** (books-and-records preservation), **Communication Compliance** (supervision of registered persons' communications), and **Audit** (the evidence trail) — **pilots them in simulation/test/disabled mode**, validates them, and produces an **evidence binder** (control → configuration → proof) you can hand to an examiner. Five safe-by-default PowerShell tools (read-only or `-WhatIf` until you commit) do the assessment, scoping, configuration, validation, and evidence reporting.

What you get

- **A rule-to-control register** — every in-scope obligation mapped to the Purview object that implements it, with the required retention/supervisory scope and a named approver.
- **Records preservation** — regulatory-records retention across email, files, and Teams, piloted with a **non-regulatory** label first and applied under compliance sign-off (regulatory records are irreversible by design).
- **Communication supervision, privacy-first** — a supervisory policy built **in test mode** with strict reviewer separation and pseudonymization where available, surfacing review items to designated reviewers.
- **An audit-evidence trail** — unified audit on, with a long-term retention policy keeping the evidence your compliance function requires.
- **An examiner-ready evidence binder** — control → configuration → proof, regenerated on a cadence so it is always current.

Approach

Delivery follows a disciplined, reversible model — **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)** — piloting every high-impact control on a limited scope before enforcement, with pass/fail gates and documented rollback. The one deliberate exception, the irreversible **regulatory-records** label, is gated hardest of all: applied only under explicit compliance sign-off.

Boundaries

Microsoft Purview is **licensing-/plan-dependent** (records/regulatory records, Communication Compliance, and Audit Premium require E5 or the E5 Compliance add-on) and the portal is **actively evolving** — capabilities and paths are cited or flagged **"verify your licensing/tenant,"** never assumed. **Communication Compliance is HR/privacy-sensitive** and is built privacy-by-design with reviewer role separation; **case outcomes are HR/legal's.** Above all: **rule applicability, retention adequacy, supervisory scope, 17a-4 compliance, and whether a configuration satisfies FINRA/SEC are deferred to your compliance, records, privacy, and legal functions** — this solution provides the technical control and the evidence, not the determination.

The bottom line

A FINRA/SEC program that is **configured, piloted, validated, and evidenced** in Microsoft Purview — so when an examiner asks to see the control and the proof, both are already in hand.

1. Solution Overview — Microsoft Purview FINRA/SEC Compliance Program

What this solution is

A regulated broker-dealer or investment adviser lives and dies by two questions from an examiner: *"Show me the control"* and *"Show me the evidence."* FINRA and SEC obligations — supervision of electronic communications, books-and-records preservation, and a demonstrable audit trail — need to be **mapped to concrete controls**, those controls **configured**, and the whole thing **evidenced** in a form you can hand to an examiner without a scramble. This solution builds that program on **Microsoft Purview**: it maps the technical control surface (records retention, communication supervision, audit) to a FINRA/SEC-aligned control register, **configures** the controls in Purview — regulatory records retention, communication-compliance (supervisory) supervision, and audit evidence retention — **pilots them in simulation/test/disabled mode first**, validates, and produces an **evidence binder** you can defend. It uses only the **Microsoft Purview portal** (`purview.microsoft.com`), **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** — no third-party tooling.

> ***This is a technical-control-and-evidence program, not a legal opinion.*** *The specific records that must be retained, for how long, under which rule; who must be supervised and against what lexicon; and whether any given configuration *satisfies* a rule are* ***regulatory, records, and legal determinations*** *deferred to your* ***compliance, records, and legal functions****. This solution provides the Purview method, the configured control, and the evidence —* ***not*** *the determination that it meets FINRA Rule 4511/3110, SEA Rule 17a-4, or the SEC Books-and-Records / Marketing rules.*

Why this matters

- **Records preservation is examinable and largely non-retroactive.** Communications and books-and-records must be preserved (historically in a non-rewriteable, non-erasable "WORM" form; SEA Rule 17a-4 was amended in 2022–2023 to also permit an **audit-trail** alternative). Purview delivers this with **regulatory records** labels and immutable retention — but only from the day they are applied

forward, which is why configuring *now* matters.

• **Communication supervision is a named control.** FINRA supervision expectations (Rule 3110) require a system to review registered persons' electronic communications. Purview **Communication Compliance** (the supervisory-review capability) is the Microsoft control that operationalizes this — and it is **HR/privacy-sensitive**, so it must be built with privacy-by-design, pseudonymization where available, and strict reviewer role separation.

• **Evidence is the deliverable examiners actually want.** A control that works but can't be *shown* to work fails an exam. This solution's reporting produces a **control-to-configuration-to-evidence** binder so "the control is in place" is provable, not asserted.

• **The controls are licensing-dependent and evolving.** Regulatory records, Communication Compliance, Audit Premium, and auto-classification require **Microsoft 365 E5** or the **E5 Compliance** add-on; the portal and rule tooling change. Capabilities are **cited or flagged "verify your licensing/tenant"**, never assumed.

How it works

1. **Assess.** Discover what you already have — compliance licensing/plans, the least-privilege roles, existing retention labels/policies, any Communication Compliance policies, unified-audit state, and audit retention — so the program is built on facts, not assumptions.

2. **Design the control map.** With compliance/records/legal, map the in-scope FINRA/SEC obligations to the three Purview control domains (records retention, communication supervision, audit evidence) and to the **named artifacts** below. The rule-to-control mapping is the compliance function's determination; this solution provides the register structure and the technical control.

3. **Configure — in simulation/test first.** Create the regulatory-records retention labels and policy, the communication-supervision policy (**in test mode**), and the audit evidence-retention policy. Every high-impact change is piloted disabled/simulated before enforcement.

4. **Pilot & validate.** Prove the labels apply and preserve, the supervision policy generates review items against test content (in test mode), and audit evidence is retained — on a bounded **pilot scope** before tenant-wide enforcement.

5. **Produce the evidence.** Generate the control-mapping + evidence binder (control → Purview object → configuration → proof) for the compliance/audit file.

6. **Expand & operate.** Move from test to enforcement on the approved scope, schedule the read-only re-assessment so drift is caught, and hand the binder and runbook to the compliance function as a standing procedure.

The control stack this solution configures

• **Records & data lifecycle** — retention **labels** (including **records** and, where licensed, **regulatory records** with immutable, un-disablable retention) and retention **policies** across Exchange, SharePoint, OneDrive, and Teams — the books-and-records preservation control.

• **Communication Compliance** — the **supervisory-review** capability that scans registered persons' electronic communications against policies/conditions and routes items to reviewers — the supervision control. *HR/privacy-sensitive.*

• **Audit (Standard/Premium)** — unified audit logging and **audit log retention policies** keeping the evidence of who did what — the audit-trail control.

• **Compliance Manager** — regulatory **assessment templates** (e.g. FINRA/SEC-relevant templates, subject to your licensing) that track improvement actions and score control implementation — the control-tracking layer (configured in-portal; determination of applicability is compliance's).

• **Disposition review** — reviewed disposal at end of retention, so records aren't kept forever without governance.

What you can control

• Which **retention labels/policies** implement the records-preservation control, their scope, and whether they use **records/regulatory records** (immutable) behavior.

• The **Communication Compliance** policy scope, conditions, and reviewers — built in **test mode** first.

• Which record types/operations/users get **extended audit retention** as evidence.

• The **control register** (which rule maps to which Purview object) and the **evidence binder** contents.

• The **pilot scope** validated in simulation/test/disabled mode before any enforcement.

Limitations (be honest with buyers)

• **We configure the control; we do not make the determination.** Retention schedules, which communications/records are in scope, supervisory lexicons, and whether a configuration satisfies a specific FINRA/SEC rule are **compliance/records/legal** determinations. **Verify with your regulatory functions.**

• **Regulatory records are effectively irreversible by design.** A **regulatory record** label cannot be removed and its retention cannot be shortened/disabled — that is the point, and the reason it is **piloted with non-regulatory records first** and only applied under explicit compliance sign-off.

• **Preservation is largely not retroactive.** Labels/policies preserve from application forward; they do not reach back to create history that wasn't captured.

• **Communication Compliance is privacy-sensitive and license-gated.** It requires the right licensing and must be built with privacy-by-design, reviewer role separation, and (where available) pseudonymization; **outcomes and case actions are HR/legal's, not this solution's.**

• **17a-4 / WORM vs audit-trail alternative, and third-party attestations.** Whether your chosen configuration meets the amended SEA Rule 17a-4 (electronic recordkeeping requirements, including the audit-trail alternative) and any required third-party/undertaking letters are **legal determinations** — **verify with counsel and your records function.**

Naming convention (used in every doc and script)

Every artifact this solution creates is named `<Purpose> – <Scope> – <Stage>` and reused verbatim across the docs, scripts, and portal. The standard set:

Artifact	Name
Regulatory-records retention label	`Records – FINRA/SEC Regulated – Regulatory`
Records retention-label publish policy	`Retention – FINRA/SEC Records – Publish`
Communications-store retention policy	`Retention – FINRA/SEC Comms Store – Immutable`
Communication-supervision policy (test)	`Supervision – Registered Persons Comms – Test`
Audit evidence retention policy	`Audit Retention – FINRA/SEC Evidence – LongTerm`
Compliance Manager assessment	`Assessment – FINRA/SEC Controls – Program`
Disposition-review stage	`Disposition – FINRA/SEC Records – Review`
Control-mapping register	`Control Map – FINRA/SEC – Purview`
Evidence binder export	`Evidence – FINRA/SEC Controls – Binder`
Pilot validation scope	`FINRA/SEC Pilot – Registered Persons – Stage1`

The standard deployment model

> *Assess the controls and licensing you have → design the rule-to-control map with compliance/legal → configure records retention, communication supervision, and audit evidence →* ***pilot in simulation/test/disabled mode*** *on a limited scope → validate the controls work and produce evidence → expand to enforcement. Pattern:* ***Assess*** *→* ***Design*** *→* ***Configure*** *→* ***Pilot (simulate/test)*** *→* ***Validate*** *→* ***Expand (enforce).*** *High-impact controls (regulatory records, supervision, retention) are always piloted before enforcement.*

2. Requirements Guide — Microsoft Purview FINRA/SEC Compliance Program

Verify **every** requirement before configuring. Each entry: **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites (tenant/licensing, Purview roles, the S&C PowerShell + Graph toolchain, in-scope workloads, compliance/records/legal stakeholders, pilot & change control) are in `global-requirements-purview.md` — this guide adds the FINRA/SEC-program detail.

> ***Regulatory/licensing boundary.*** *Regulatory records, Communication Compliance, Audit Premium, and auto-classification require* ***Microsoft 365 E5*** *or the* ***E5 Compliance*** *add-on and evolve; confirm your entitlements rather than assuming.* ***Which rules apply, which records/communications are in scope, which retention periods and supervisory lexicons are required, and whether a configuration satisfies FINRA/SEC*** *are* ***compliance/records/legal determinations*** *— this solution configures the control and produces evidence; it does not make the determination. Where this guide flags "verify your licensing/tenant" or "compliance/legal to determine," do so before relying on the item.*

2.1 Compliance licensing for records, supervision, and audit evidence

Description: The program spans three licensed control domains. **Records/regulatory-records retention** and **auto-classification** need **E5 / E5 Compliance**; **Communication Compliance** needs **E5 / E5 Compliance** (or the Insider Risk Management add-on family); **Audit Premium** (high-value events, long-term retention) needs **E5 / E5 Compliance / Audit add-on**, assigned **per user**. **Why:** Every control below is plan-gated; the feature won't be available without the right plan (GR §1). **Verify:** M365 admin center → `Billing → Licenses`; and run `CMPFINRA-Discovery.ps1`, which reports whether records/Communication-Compliance/Audit-Premium-bearing plans are present via Graph. **Confirm plan/service-plan names against your tenant — they change. Implement:** Assign/purchase E5 or the relevant add-ons to in-scope users before expecting the feature.

2.2 Least-privilege roles with reviewer separation

Description: Distinct least-privilege roles for each domain — **Records Management** / **Retention Management** for labels & policies; **Compliance Administrator** / **Communication Compliance** role groups (Admin, Analyst, Investigator, Viewer) for supervision, kept **separate** from the configuring admin; **Audit Manager/Reader** for evidence; **Compliance Manager** roles for assessments. Global Administrator only where genuinely required. **Why:** Purview uses fine-grained role groups; **Communication Compliance is HR/privacy-sensitive and demands reviewer role separation** so configurers can't self-review and reviewers see only their scope (GR §2). **Verify:** Purview portal → `Settings → Roles & scopes / Permissions` — confirm membership per domain; `CMPFINRA-Scope.ps1` reports the role groups it can see and connection identity. **Implement:** Assign the least-privilege role groups under change control; document the reviewer separation for the supervision control.

2.3 Security & Compliance PowerShell + Graph toolchain

Description: A workstation with the `ExchangeOnlineManagement` module (for `Connect-IPPSSession` — retention labels/policies, `*-RetentionCompliancePolicy`/`*-ComplianceTag`, `*-SupervisoryReview*`, `*-UnifiedAuditLogRetentionPolicy`) and `Microsoft.Graph` (licensing reads), with a modern-auth/MFA admin. **Why:** All configuration and the provided scripts run through Security & Compliance PowerShell and Graph (GR §3). **Verify:** `Get-Module -ListAvailable ExchangeOnlineManagement`; `Connect-IPPSSession` and `Connect-MgGraph` succeed; `CMPFINRA-Discovery.ps1` reports which endpoints are reachable. **Implement:** `Install-Module ExchangeOnlineManagement -Scope CurrentUser`; `Install-Module Microsoft.Graph -Scope CurrentUser`.

2.4 In-scope population, workloads, and communications channels

Description: The **registered/covered persons** in scope, the **workloads** holding books-and-records (Exchange, SharePoint, OneDrive, Teams) and the **communication channels** to supervise (Exchange email, Teams chat/channels, and any connected channels), plus a **classification intent** to drive labels. **Why:** Retention, supervision, and audit controls key off the in-scope population/workloads/channels (GR §4). **Verify:** Confirm the population (a group/OU of covered persons), the in-scope workloads/channels, and the classification approach with compliance; `CMPFINRA-Scope.ps1` enumerates the target group's members and the mailboxes/sites in scope (read-only). **Implement:** Define the covered-persons group

and the in-scope workloads/channels before authoring controls.

2.5 The rule-to-control map and retention schedule (from compliance/records/legal)

Description: A documented statement — **from compliance, records, and legal** — of which FINRA/SEC obligations are in scope, what must be **retained and for how long** (the records schedule), which communications must be **supervised** and against what conditions/lexicon, and who approves. **Why:** Rule applicability, retention duration, and supervisory scope are **regulatory/legal determinations**, not technical defaults (GR §5); the solution configures to them and evidences them — it does not decide them. **Verify:** You can name, per control domain, the obligation, the required retention/supervision, and the named approver; these populate the `Control Map – FINRA/SEC – Purview` register. **Implement:** Capture the rule-to-control map, retention schedule, and supervisory scope with approvals before configuring — especially before any **regulatory-records** (irreversible) label.

2.6 Communication Compliance privacy & governance preconditions

Description: For the supervision control specifically: agreement on **privacy-by-design** (data minimization, **pseudonymization** of monitored users where the tenant supports it), **reviewer role separation**, works-council/employee-notice obligations where applicable, and the disposition of review outcomes. **Why:** Supervision reads employees' communications — it is HR/privacy-sensitive; outcomes and case actions are **HR/legal's**, and mis-scoped monitoring is a privacy risk (GR §5, and the category's insider-risk/comms-compliance sensitivity rule). **Verify:** Named reviewers (separated from configurers), a privacy/notice sign-off, and whether pseudonymization is enabled in the tenant. **Implement:** Obtain the privacy sign-off and reviewer roster; enable pseudonymization if required; **build the policy in test mode** until sign-off is complete.

2.7 Unified audit logging on, and an evidence-retention requirement

Description: `UnifiedAuditLogIngestionEnabled` must be **true** so the audit-trail control captures evidence, plus a documented statement of how long audit **evidence** must be retained. **Why:** No audit evidence is written while ingestion is off, and it is **not retroactive**; retention duration is a compliance determination (GR §5/§6). **Verify:** `CMPFINRA-Discovery.ps1` reports `UnifiedAuditLogIngestionEnabled` and existing audit retention policies. **Implement:** Enable unified audit under change control (via the Purview Audit solution / Exchange Online), then create the evidence-retention policy in Step 4 of the Implementation Guide.

2.8 A pilot scope, simulation/test mode, and change control

Description: A bounded **pilot scope** (`FINRA/SEC Pilot – Registered Persons – Stage1` — a small set of covered persons/mailboxes/sites) and a **change-control** window. Retention labels can be trialed with **non-regulatory** records first; Communication Compliance supports a **test mode**; audit changes are reversible. **Why:** Records/regulatory-records, supervision, and retention are **high-impact** — regulatory records are effectively irreversible — so every change is piloted in simulation/test/disabled mode before enforcement (GR §6). **Verify:** A named pilot scope, confirmation that test/disabled mode is available for each control, and a change window/approval path. **Implement:** Define the pilot scope and agree change control before enabling or applying any control — **never apply a regulatory-records label**

outside the pilot without explicit compliance sign-off.

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

- **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires

(E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

- **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the

right plan.

- **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is

visible in the Purview portal.

- **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

- **Description:** Access with the least-privilege **Purview / compliance role** the solution names

(e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

- **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.
- **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.
- **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

- **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

- **Why required:** Configuration, automation, and the provided scripts run through these.
- **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.
- **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

- **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams,

endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.

- **Why required:** Purview policies key off the in-scope workloads and the classification scheme.
- **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with

stakeholders.

- **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

- **Description:** Engagement with the **compliance, records-management, privacy, security, and legal**

stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).

- **Why required:** Purview configuration must align to enterprise policy and legal/records requirements,

not technical defaults; several capabilities have HR/legal sensitivity.

- **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.
- **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

- **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate

on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.

- **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate

→ Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.

- **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change

window/approval path.

- **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — Microsoft Purview FINRA/SEC Compliance Program

Follow these steps **in order**. Configuration uses the **Microsoft Purview portal** (`https://purview.microsoft.com`), **Security & Compliance PowerShell** (`Connect-IPPSSession` — the `*-RetentionCompliancePolicy`, `*-ComplianceTag`, `*-SupervisoryReview*`, and `*-UnifiedAuditLogRetentionPolicy` cmdlets), and **Microsoft Graph** (licensing). Every write is gated: scripts run **read-only or `-WhatIf` by default** and only change state with `-Commit`. Artifact names follow the `<Purpose> – <Scope> – <Stage>` convention from the Overview and are reused verbatim.

> ***Model:** Assess the controls/licensing you have → design the rule-to-control map with compliance/legal → configure records retention, communication supervision, and audit evidence → **pilot in simulation/test/disabled mode** → validate and evidence → expand to enforcement. Pattern: **Assess → Design → Configure → Pilot (simulate/test) → Validate → Expand (enforce). Determination boundary:** which rules apply, retention durations, supervisory scope/lexicons, and whether a configuration *satisfies* FINRA/SEC are **compliance/records/legal** determinations. This guide configures the control and evidences it; it does not make the determination. **A `regulatory-records` label is effectively irreversible — never apply it outside the pilot without explicit compliance sign-off.***

Step 1 — Assess current controls and licensing (Assess)

1. Run `CMPFINRA-Discovery.ps1` (read-only). It connects to Security & Compliance PowerShell and Graph and reports:

• compliance licensing present (records / Communication Compliance / Audit Premium-bearing plans — **verify plan names for your tenant**),

• existing **retention labels** (`Get-ComplianceTag`) and **retention policies** (`Get-RetentionCompliancePolicy`), flagging any that are **records/regulatory records**,

• existing **Communication Compliance** (supervisory-review) policies (`Get-SupervisoryReviewPolicyV2`),

• `UnifiedAuditLogIngestionEnabled` and existing **audit retention policies** (`Get-UnifiedAuditLogRetentionPolicy`).

1. Run `CMPFINRA-Scope.ps1` (read-only) to enumerate the intended covered-persons group, in-scope mailboxes/sites, and the role groups it can see (Requirement 2.2/2.4).

2. Record the gaps against the three control domains. **Pass gate:** a written current-state for records, supervision, and audit.

Step 2 — Design the rule-to-control map (Design)

1. With compliance/records/legal (Requirement 2.5), populate the `Control Map – FINRA/SEC – Purview` register: for each in-scope obligation, name the Purview control object that implements it, the required retention/supervisory scope, and the approver. **The rule-to-control mapping is compliance's determination; you provide the register and the technical control.**

2. Map the obligations to the standard named artifacts:

• Records preservation → `Records – FINRA/SEC Regulated – Regulatory` (label) + `Retention – FINRA/SEC Records – Publish` (publish policy) + `Retention – FINRA/SEC Comms Store – Immutable` (comms-store retention).

• Communication supervision → `Supervision – Registered Persons Comms – Test`.

• Audit evidence → `Audit Retention – FINRA/SEC Evidence – LongTerm`.

• Control tracking → `Assessment – FINRA/SEC Controls – Program` (Compliance Manager).

1. Define the pilot scope `FINRA/SEC Pilot – Registered Persons – Stage1` (Requirement 2.8) and the privacy/reviewer sign-off for supervision (Requirement 2.6). **Pass gate:** the control map, retention schedule, supervisory scope, pilot, and approvals are documented.

Step 3 — Configure the records-preservation control (Configure → Pilot)

1. **Pilot with a non-regulatory records label first** to prove behavior safely. Create the labels and publish policy with the helper, `-WhatIf` first (prints the exact `New-ComplianceTag`/`New-RetentionCompliancePolicy` it would run):

• `CMPFINRA-Configure.ps1 -Control Records -PilotLabel -WhatIf` → review → `-Commit` (creates a **records** — not regulatory — label for pilot testing, plus `Retention – FINRA/SEC Records – Publish` scoped to the pilot).

1. Validate the pilot label applies and preserves on pilot content (Testing Gate 2). **Only after compliance sign-off**, create the production **regulatory record** label `Records – FINRA/SEC Regulated – Regulatory` (immutable, un-disablable) and, where the design calls for immutable comms preservation, the `Retention – FINRA/SEC Comms Store – Immutable` location-based retention policy across Exchange/Teams:

• `CMPFINRA-Configure.ps1 -Control Records -Regulatory -WhatIf` → review → `-Commit`.

1. **Pass gate:** `CMPFINRA-Discovery.ps1` lists the labels/policies with the expected records/regulatory behavior and scope. **Rollback:** the **non-regulatory** pilot label/policy is removable (`-Control Records -Remove -Commit`); a **regulatory-records** label is **not removable and its retention cannot be shortened by design** — this is why sign-off precedes it (verify behavior in your tenant before committing).

Step 4 — Configure the audit-evidence control (Configure)

1. Confirm unified audit is on (Requirement 2.7). Create the evidence-retention policy pilot-first:

• `CMPFINRA-Configure.ps1 -Control Audit -PolicyName "Audit Retention – FINRA/SEC Evidence – LongTerm" -WhatIf` → review → `-Commit` (creates a `New-UnifiedAuditLogRetentionPolicy` for the record types/operations your compliance function requires as evidence, at the agreed duration and a unique priority). **Verify accepted** `RetentionDuration` **values and that the long-term tier is licensed** (Requirement 2.1).

1. **Pass gate:** `CMPFINRA-Discovery.ps1` lists the audit retention policy with the expected duration/priority. **Rollback:** `CMPFINRA-Configure.ps1 -Control Audit -PolicyName "…" -Remove -Commit` (already-retained records age out under remaining rules).

Step 5 — Configure the communication-supervision control — IN TEST MODE (Configure → Pilot)

1. **Build the supervision policy in test/pilot mode** with reviewer separation in place (Requirement 2.6). The helper creates it disabled/test-scoped to the pilot covered persons:

• `CMPFINRA-Configure.ps1 -Control Supervision -PilotScope "FINRA/SEC Pilot – Registered Persons – Stage1" -WhatIf` → review → `-Commit` (creates `Supervision – Registered Persons Comms – Test` via `New-SupervisoryReviewPolicyV2`, scoped to the pilot group and its supervising reviewers, with the conditions your compliance function specified — **the lexicon/conditions are compliance's determination**).

1. Confirm the policy generates review items against **benign test communications** for the pilot group, and that only the designated reviewers can see them. **Do not enforce tenant-wide, and do not action any real item — case actions/outcomes are HR/legal's.**

2. **Pass gate:** the test policy exists, is scoped to the pilot with correct reviewer separation, and surfaces test items. **Rollback:** disable/remove the test policy (`-Control Supervision -Remove -Commit`); no employee communications are altered by the control.

Step 6 — Track the program in Compliance Manager (Configure, in-portal)

1. In the Purview portal → **Compliance Manager**, create/assign the assessment `Assessment – FINRA/SEC Controls – Program` from a FINRA/SEC-relevant **assessment template** (**template availability depends on your licensing — verify in-portal**). Map its improvement actions to the Purview controls configured above.

2. Record, per improvement action, the implementing Purview object and its evidence location (this cross-links to the `Control Map – FINRA/SEC – Purview` register). **Pass gate:** the assessment reflects the configured controls with evidence links. *(Compliance Manager assessment content and applicability are compliance's determination; no cmdlet invents this — it is authored in-portal.)*

Step 7 — Validate the controls and generate evidence (Validate)

1. Run `CMPFINRA-Validate.ps1` (read-only) to score the program across gates: labels/policies present and correctly typed, comms-store retention scoped, audit ingestion on with the evidence policy in place, the supervision policy present in test with reviewer separation, and the pilot scope covered.

2. Run `CMPFINRA-Report.ps1` (read-only) to produce `Evidence – FINRA/SEC Controls – Binder` — a control → Purview object → configuration → proof export (CSV/JSON) for the compliance/audit file, cross-referenced to `Control Map – FINRA/SEC – Purview`.

3. Complete the **Testing Guide** before expanding. **Pass gate:** the validation scorecard is green for the pilot scope and the evidence binder is generated.

Step 8 — Expand to enforcement and operationalize (Expand)

1. Once the pilot passes and compliance signs off, expand scope: publish the **regulatory-records** label to the full covered-persons/workload scope, extend the comms-store retention and audit-evidence policies, and **move the supervision policy from test to enforced** (compliance-approved) coverage — each under change control.

2. Configure the `Disposition – FINRA/SEC Records – Review` stage so end-of-retention disposal is reviewed, not automatic (where the records schedule requires disposition review).

3. Schedule the read-only chain (`CMPFINRA-Discovery.ps1` → `CMPFINRA-Validate.ps1` → `CMPFINRA-Report.ps1`) on a cadence so drift — a disabled policy, a removed label scope, a lapsed license, audit turned off — is caught, and re-generate the evidence binder before each exam. **Pass gate:** controls enforced tenant-wide on the approved scope, evidence binder current, monitoring cadence scheduled. Hand the register, binder, and runbook to the compliance function as the standing procedure.

5. Testing & Validation — Microsoft Purview FINRA/SEC Compliance Program

Work through every gate. Each has a **method**, an **expected result (pass)**, and a **fail action**. Tests are read-only or use **benign, self-generated pilot content** — no production records or real employee communications are actioned. Do not declare "FINRA/SEC-ready" until every gate passes for the pilot scope, then re-confirm on expand.

> ***Boundary:*** *these gates prove the* ***technical control works and is evidenced****. Whether the control* ***satisfies*** *a specific FINRA/SEC rule — retention adequacy, supervisory scope/lexicon sufficiency, 17a-4 electronic-recordkeeping compliance — is a* ***compliance/records/legal determination****, not a test outcome.* ***Never action a real supervision item during testing — outcomes are HR/legal's.***

Gate 1 — Compliance licensing present for each control

- **Method:** `CMPFINRA-Discovery.ps1` licensing section (Graph `subscribedSkus` / service plans).
- **Pass:** records/regulatory-records, Communication Compliance, and Audit Premium-bearing plans are present and assigned to the in-scope population.
- **Fail:** assign the license (Requirement 2.1); a missing plan makes the corresponding control unavailable — that is a licensing gap, not a config defect. **Verify plan names for your tenant.**

Gate 2 — Records label applies and preserves (pilot, non-regulatory first)

• **Method:** apply the **non-regulatory** pilot records label to benign pilot content, attempt to edit/delete it, then confirm via `CMPFINRA-Discovery.ps1` / portal that retention held.

• **Pass:** the label applies, records behavior prevents disallowed deletion, and `Get-ComplianceTag`/`Get-RetentionCompliancePolicy` show it scoped to the pilot.

• **Fail:** confirm the label type (`-IsRecordLabel`), the publish policy scope, and label availability latency; retest. **Do not proceed to the regulatory-records label until this passes and compliance signs off.**

Gate 3 — Regulatory-records behavior confirmed (post sign-off)

• **Method:** after compliance sign-off, confirm `Records – FINRA/SEC Regulated – Regulatory` exists as a **regulatory** record label (immutable, retention non-shortenable) on the approved scope.

• **Pass:** the label is present and typed regulatory; its irreversibility is understood and documented.

• **Fail:** verify the regulatory-record behavior in your tenant before wider application; a regulatory label **cannot be undone**, so treat any doubt as a stop.

Gate 4 — Communications-store retention scoped

• **Method:** `CMPFINRA-Discovery.ps1` / portal — confirm `Retention – FINRA/SEC Comms Store – Immutable` covers the in-scope Exchange/Teams locations for the pilot.

• **Pass:** the retention policy exists, is enabled, and covers the intended comms locations at the agreed duration.

• **Fail:** correct the locations/duration with `CMPFINRA-Configure.ps1 -Control Records`; re-verify. Confirm the retention duration with compliance (determination).

Gate 5 — Unified audit on and evidence policy present

• **Method:** `CMPFINRA-Discovery.ps1` audit section (`UnifiedAuditLogIngestionEnabled`, `Get-UnifiedAuditLogRetentionPolicy`).

• **Pass:** ingestion is `True` and `Audit Retention – FINRA/SEC Evidence – LongTerm` exists with the agreed duration and a unique priority.

• **Fail:** enable ingestion under change control; create/correct the policy (Implementation Step 4); verify the `RetentionDuration` value and licensing.

Gate 6 — Supervision policy exists in TEST with reviewer separation

• **Method:** `CMPFINRA-Discovery.ps1` / `CMPFINRA-Validate.ps1` — confirm `Supervision – Registered Persons Comms – Test` (`Get-SupervisoryReviewPolicyV2`) is scoped to the pilot group, in test, and that reviewers are separated from the configuring admin (Requirement 2.2/2.6).

• **Pass:** the test policy exists, is pilot-scoped, and only designated reviewers can access its items.

• **Fail:** correct scope/reviewers; **do not enforce or action real items**. If pseudonymization is required and not enabled, resolve before proceeding.

Gate 7 — Supervision surfaces test items (benign)

• **Method:** generate **benign test communications** matching the policy conditions for a pilot user; confirm a review item appears to the designated reviewer.

• **Pass:** a review item is generated and visible only to the reviewer.

• **Fail:** confirm the policy conditions/scope and ingestion latency; adjust and retest. **Conditions/lexicon adequacy is compliance's determination, not a test.**

Gate 8 — Control map and evidence binder generated

• **Method:** `CMPFINRA-Report.ps1` → `Evidence – FINRA/SEC Controls – Binder`, cross-referenced to `Control Map – FINRA/SEC – Purview`.

• **Pass:** every in-scope obligation maps to a Purview object with its configuration and a proof reference; the binder exports cleanly.

• **Fail:** fill the gap (missing control or missing evidence) and re-run. A control with no evidence fails an exam.

Gate 9 — Validation scorecard is green (pilot)

• **Method:** `CMPFINRA-Validate.ps1`.

• **Pass:** every gate above is green for the pilot scope (and, on expand, for the approved production scope).

• **Fail:** address the specific red item and re-run before enforcing anything tenant-wide.

Evidence to retain

• `CMPFINRA-Discovery.ps1` and `CMPFINRA-Validate.ps1` outputs (before/after).

• The `-WhatIf` transcripts for every label, retention, audit, and supervision change.

• The `Evidence – FINRA/SEC Controls – Binder` export and the `Control Map – FINRA/SEC – Purview` register.

• The compliance sign-offs (regulatory-records application, supervisory scope, retention schedule) and the pilot roster/approvals (Requirement 2.5/2.6/2.8).

*Retention adequacy, supervisory-scope sufficiency, 17a-4 compliance, and rule applicability are **compliance/records/legal determinations** — these gates prove the Purview controls work and are evidenced, not that the program satisfies the regulation.*

6. Troubleshooting — Microsoft Purview FINRA/SEC Compliance Program

Symptom → likely cause → fix, for the failure modes you are most likely to hit. Diagnosis is read-only: run `CMPFINRA-Discovery.ps1`, `CMPFINRA-Scope.ps1`, and `CMPFINRA-Validate.ps1` first — they name the specific gap and the Implementation step that closes it. Remember the boundary throughout:

these fixes make the **technical control** work and be **evidenced**; whether a control **satisfies** a FINRA/SEC rule is a **compliance/records/legal determination**.

A capability is missing entirely (label type, supervision, audit tier) — likely a licensing gap

- **Cause:** Records/regulatory-records, Communication Compliance, and Audit Premium are **plan-gated** (Microsoft 365 **E5** or the **E5 Compliance** add-on; Requirement 2.1). If the plan/service plan is absent or unassigned to the in-scope user, the control simply isn't available — that is a licensing gap, not a configuration defect.
- **Fix:** `CMPFINRA-Discovery.ps1` licensing section reports the indicative plans; confirm in **M365 admin center → Billing → Licenses **and assign the right plan to the in-scope population.** Plan and service-plan names change — verify them for your tenant** rather than trusting the script's indicative list.

`Connect-IPPSSession` fails or cmdlets are "not recognized"

- **Cause:** The `ExchangeOnlineManagement` module isn't installed/updated, you're not on modern auth/MFA, or you ran a Security & Compliance cmdlet in the wrong session.
- **Fix:** `Install-Module ExchangeOnlineManagement -Scope CurrentUser` (update if old); `Connect-IPPSSession` with an MFA-capable admin. Note the **two different sessions**: retention labels, DLP, supervision, and audit-retention cmdlets are **Security & Compliance PowerShell** (`Connect-IPPSSession`), while `Get-AdminAuditLogConfig` runs in **Exchange Online PowerShell** (`Connect-ExchangeOnline`). `CMPFINRA-Validate.ps1` falls back to `Connect-ExchangeOnline` for the ingestion check — connect there if the audit gate can't read config.

`Get-SupervisoryReviewPolicyV2` (or the supervision cmdlets) error / not found

- **Cause:** The Communication Compliance feature/cmdlet set isn't available for your tenant/licensing, or your account lacks the Communication Compliance role.
- **Fix:** Confirm Communication Compliance licensing (Requirement 2.1) and that you hold the least-privilege **Communication Compliance** role (Requirement 2.2). The cmdlet surface for supervision has **changed over time and varies by tenant** — **verify the current cmdlet/feature for your tenant** in Microsoft's documentation before assuming a defect. Build the policy **in test mode** regardless.

Records/regulatory-records label applied but content can still be deleted, or label isn't visible

- **Cause:** Label **publish latency** (a published label can take time to appear), the publish policy isn't scoped to the location, or the label was created as **retain-only** rather than a **record** (`-IsRecordLabel`)/**regulatory record** (`-Regulatory`).

• **Fix:** Confirm the label type with `Get-ComplianceTag` (`IsRecordLabel`/`RegulatoryRecord`), confirm

`Retention – FINRA/SEC Records – Publish` covers the pilot location, and allow for propagation before retesting (Testing Gate 2). **Pilot with the non-regulatory label first** — never chase this on a regulatory-records label.

"I need to undo a regulatory-records label" — you can't

• **Cause:** A **regulatory record** label is **immutable and cannot be removed**, and its retention

cannot be shortened or disabled — by design (that is the point of the control).

• **Fix:** There is no rollback. This is exactly why the model **pilots with a non-regulatory records

label first **and applies the regulatory label** only under explicit compliance sign-off **on the approved scope. If you applied it in error, this is a** compliance/records** escalation, not a technical fix. Treat any doubt before committing as a stop.

Comms-store retention policy exists but Validate shows it DISABLED or out of scope

• **Cause:** The policy was created disabled, or its locations don't cover the intended Exchange/Teams

targets.

• **Fix:** `CMPFINRA-Discovery.ps1` shows `Enabled`/`Workload`; correct the scope/enable it with

`CMPFINRA-Configure.ps1 -Control Records` and re-run `CMPFINRA-Validate.ps1` (Testing Gate 4). Confirm the **retention duration** with compliance — the duration is their determination, not a default.

Audit gate red: ingestion off, or evidence policy missing

• **Cause:** `UnifiedAuditLogIngestionEnabled` is **False** (no evidence is being written, and it is

not retroactive), or `Audit Retention – FINRA/SEC Evidence – LongTerm` doesn't exist / uses an invalid `RetentionDuration` for your tenant/licensing.

• **Fix:** Enable unified audit under change control (Purview Audit solution / Exchange Online), then

create the policy with `CMPFINRA-Configure.ps1 -Control Audit` (Implementation Step 4). **Verify the accepted** `RetentionDuration` **values and that the long-term tier is licensed** (Requirement 2.1) — an unlicensed long-term duration is rejected.

Supervision policy created but no review items appear

• **Cause:** No content yet matches the policy conditions, ingestion/indexing latency, the supervised

users aren't the pilot population, or the conditions/lexicon don't match your test content.

• **Fix:** Generate **benign test communications** matching the conditions for a pilot user, allow for

latency, and confirm the policy's supervised users are the pilot group and reviewers are the designated (separated) reviewers (Testing Gates 6–7). **Never action a real item to "test" it — outcomes are**

HR/legal's. Whether the conditions/lexicon are **adequate** is compliance's determination, not a test result.

Reviewers can see too much, or the configuring admin can self-review

- **Cause: Reviewer role separation** wasn't enforced — a privacy/governance defect, not a bug.
- **Fix:** Separate the **Communication Compliance** reviewer roles from the configuring admin

(Requirement 2.2/2.6); enable **pseudonymization** where the tenant supports it; obtain the privacy/ notice sign-off. `CMPFINRA-Scope.ps1` lists visible role groups to check separation. Keep the policy in **test** until this is resolved.

Graph licensing or population check fails

- **Cause:** `Microsoft.Graph` isn't installed, consent for `Organization.Read.All` /

`Directory.Read.All` / `Group.Read.All` / `User.Read.All` wasn't granted, or the covered-persons group display name is wrong.

- **Fix:** `Install-Module Microsoft.Graph -Scope CurrentUser`; consent to the delegated scopes at

`Connect-MgGraph`; pass the **exact** group display name to `CMPFINRA-Scope.ps1 -CoveredPersonsGroup`. Use `-SkipGraphLicensing` / `-SkipGraph` to run the S&C-only sections if Graph is unavailable.

Evidence binder has gaps (a control with no proof)

- **Cause:** A control isn't configured, or it's configured but the report can't resolve its object

(name mismatch) — either way it exports as `Present=False`.

- **Fix:** `CMPFINRA-Report.ps1` lists every missing object; either configure the control (Implementation

Steps 3–6) or correct the artifact name so it matches the **verbatim** naming convention (Overview §"Naming convention"). Re-run until no control is missing — **a control with no evidence fails an exam** (Testing Gate 8).

A `-Commit` change didn't take effect

- **Cause:** `-WhatIf` and `-Commit` were both passed (`-WhatIf` wins — nothing changes), or the cmdlet

errored mid-run.

- **Fix:** Re-run with **only** `-Commit` (no `-WhatIf`), read the error, and confirm with

`CMPFINRA-Discovery.ps1` / `CMPFINRA-Validate.ps1`. The Configure helper prints `SAFE MODE` when no write will occur — if you see it, you're still in preview.

Everything passes for the pilot but you're unsure you're "FINRA/SEC-ready"

- **Cause:** Green gates prove the **technical controls are present, working, and evidenced** — they do

not certify regulatory compliance.

• **Fix:** Take the `Evidence – FINRA/SEC Controls – Binder` and `Control Map – FINRA/SEC – Purview` to

your **compliance, records, and legal** functions for the determination (retention adequacy, supervisory scope/lexicon, 17a-4 compliance, rule applicability). Then expand from pilot to enforcement under change control and schedule the read-only monitoring chain so drift is caught before an examiner finds it.

7. Best Practices — A Defensible FINRA/SEC Program on Microsoft Purview

Operating principles for a control-and-evidence program that survives an examination. Grounded in Microsoft's public guidance and the **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)** model.

Stay in your lane: configure the control, defer the determination

• **You implement and evidence controls; compliance/records/legal decide the rules.** Which obligations apply, retention durations, supervisory scope and lexicons, and whether a configuration satisfies FINRA Rule 4511/3110, SEA Rule 17a-4, or the SEC Marketing/Books-and-Records rules are **their** determinations. Capture them in the `Control Map – FINRA/SEC – Purview` register with named approvers — the register is your defensibility.

• Write findings as "the control is configured as specified and evidenced," never "the firm is compliant."

Treat regulatory records as one-way doors

• A **regulatory record** label is **immutable and cannot be removed**, and its retention **cannot be shortened or disabled** — by design. **Pilot with a non-regulatory records label first**, prove behavior, and apply the regulatory label only under **explicit compliance sign-off** and on the approved scope.

• Verify the **exact** records/regulatory-records behavior in **your** tenant before wider application; when in doubt, stop — irreversibility is unforgiving.

Records preservation is (mostly) not retroactive

• Labels and policies preserve **from application forward**. Configure now; every deferred day is history you cannot recreate. This is the strongest argument for building the program before an exam, not during one.

• Know the **17a-4 options**: the amended rule permits both a traditional **WORM** approach and an **audit-trail alternative** — which one your configuration relies on, and whether it meets the rule (including any third-party/undertaking requirements), is a **legal determination**. Verify with counsel.

Build supervision privacy-first, and separate the roles

• **Communication Compliance reads employees' communications** — build it with **privacy-by-design**: minimize scope to covered persons, enable **pseudonymization** where the tenant supports it, honor employee-notice/works-council obligations, and keep **reviewers strictly separated** from configurers.

• **Always start in test mode.** Prove the policy surfaces the right items to the right reviewers before enforcing, and **never action a real item as part of implementation** — case outcomes are **HR/legal's**.

• Keep conditions/lexicons owned by compliance; you operationalize what they define, you don't invent supervisory criteria.

Make evidence a first-class deliverable

• An examiner wants **control** → **configuration** → **proof**. Generate the `Evidence – FINRA/SEC Controls – Binder` regularly, not just at exam time, so evidence is always current and gaps surface early.

• Retain the `-WhatIf` transcripts, before/after discovery outputs, and sign-offs — the *change history* of the control is itself evidence of a governed program.

Audit is the evidence layer — keep it on and retained

• Ensure **unified audit logging** stays on (it can be disabled) and that the `Audit Retention – FINRA/SEC Evidence – LongTerm` policy keeps the evidence your compliance function requires, at a verified duration and licensing tier.

• Treat "is auditing on and retaining?" as a **standing monitored control**, caught by the scheduled read-only chain.

Least-privilege everywhere, reviewed periodically

• Records Management, Communication Compliance (Admin/Analyst/Investigator/Viewer), Audit, and Compliance Manager roles are **distinct and least-privilege**; reserve Global Administrator for one-time enablement. Review membership periodically — access to supervision and records is itself sensitive.

Pilot every change, keep a rollback (except where you can't)

• Enable, retain, and supervise **pilot-first** in simulation/test/disabled mode; validate with the scorecard before expanding. Non-regulatory labels, retention policies, audit policies, and test supervision policies are reversible — record the exact rollback with every change.

• The one deliberate exception is the **regulatory-records** label: it is *meant* to be irreversible. Its "rollback" is not applying it until sign-off is complete — so gate it hardest of all.

Operate it as a program, not a project

• Schedule `CMPFINRA-Discovery.ps1` → `CMPFINRA-Validate.ps1` → `CMPFINRA-Report.ps1` on a cadence so drift (a disabled policy, a narrowed scope, a lapsed license, audit turned off) is caught before an examiner finds it, and re-generate the evidence binder ahead of every exam cycle. Hand the register, binder, and runbook to compliance as the standing procedure.

8. Deliverables Summary — Microsoft Purview FINRA/SEC Compliance Program

What you receive, what to run, and what "done" looks like.

Documentation

Document	Purpose
1. Solution Overview	What the program is, the three Purview control domains (records retention, communication supervision, audit evidence), what you control, honest limitations, and the naming convention.
2. Requirements Guide	FINRA/SEC-program prerequisites (licensing per control, least-privilege roles with reviewer separation, S&C PowerShell + Graph toolchain, in-scope population/channels, the rule-to-control map, comms-compliance privacy preconditions, audit, pilot) — each with Verify / Implement.
3. Implementation Guide	Ordered steps: assess, design the control map, configure records/audit/supervision, track in Compliance Manager, validate & evidence, expand to enforcement — pilot-in-simulation/test-first with pass/fail gates and rollback (and the regulatory-records irreversibility gate).
5. Testing & Validation	Nine gates from "licensing present" to "validation scorecard green," each with method / pass / fail action — read-only or benign pilot content.
6. Troubleshooting	The failure modes — label/record behavior, retention scope, supervision privacy/scope, audit off, licensing, endpoint confusion, evidence gaps — and their fixes.
7. Best Practices	Defensible-program principles: defer determinations, treat regulatory records as one-way, build supervision privacy-first, make evidence first-class, operate it as a program.

PowerShell tools (5)

All run **read-only or `-WhatIf` by default**; writes require `-Commit`. No credentials or secrets are embedded. Retention labels/policies, Communication Compliance (supervisory-review), and audit retention cmdlets use **Security & Compliance PowerShell** (`Connect-IPPSSession`); licensing reads use **Microsoft Graph**.

Script	Role	Default		
`CMPFINRA-Discovery.ps1`	Assess: licensing, retention labels/policies (records/regulatory), Communication Compliance policies, unified-audit state + audit retention.	Read-only		
`CMPFINRA-Scope.ps1`	Scope/health helper: covered-persons group members, in-scope mailboxes/sites, visible role groups, connection identity/health.	Read-only		
`CMPFINRA-Configure.ps1`	Configure/Remediate: create records labels + publish/comms-store retention, audit-evidence retention, and the supervision policy **in test** — `-Control Records\	Audit\	Supervision`.	`-WhatIf` (writes on `-Commit`)
`CMPFINRA-Validate.ps1`	Validate: program scorecard across records, comms-store retention, audit, supervision (test + reviewer separation), pilot coverage.	Read-only		
`CMPFINRA-Report.ps1`	Report: control → object → configuration → proof export (`Evidence – FINRA/SEC Controls – Binder`), cross-referenced to the control map.	Read-only		

Named artifacts created

• Records: `Records – FINRA/SEC Regulated – Regulatory` (label), `Retention – FINRA/SEC Records – Publish` (publish policy), `Retention – FINRA/SEC Comms Store – Immutable` (comms-store retention).

• Supervision: `Supervision – Registered Persons Comms – Test` (built and validated in test mode).

• Audit evidence: `Audit Retention – FINRA/SEC Evidence – LongTerm`.

• Program tracking: `Assessment – FINRA/SEC Controls – Program` (Compliance Manager, in-portal).

• Governance/evidence: `Disposition – FINRA/SEC Records – Review`, `Control Map – FINRA/SEC – Purview`, `Evidence – FINRA/SEC Controls – Binder`, pilot `FINRA/SEC Pilot – Registered Persons – Stage1`.

Definition of done

• Compliance **licensing confirmed** for records, supervision, and audit evidence on the in-scope population.

• Records-preservation control in place — pilot **non-regulatory** label validated, then the **regulatory-records** label applied on the approved scope **under compliance sign-off**, plus comms-store retention.

• **Unified audit on** with `Audit Retention – FINRA/SEC Evidence – LongTerm` retaining evidence.

• Communication supervision policy present **in test** with correct **reviewer separation**, surfacing benign test items.

• The `Control Map – FINRA/SEC – Purview` register complete and the `Evidence – FINRA/SEC Controls – Binder` generated; the **validation scorecard green** for the pilot — then expanded to enforcement with a monitoring cadence and disposition review scheduled.

Boundary: *this solution delivers the technical control configuration and the evidence.* ***Rule applicability, retention adequacy, supervisory scope/lexicon sufficiency, 17a-4 compliance, and any regulatory determination are deferred to your compliance, records, privacy, and legal functions.*** *Feature availability is* ***licensing-/tenant-dependent and evolving — verify against your entitlements and current Microsoft documentation.***

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

CMPFINRA-Configure.ps1

Purpose: Configures one FINRA/SEC control domain at a time (-Control Records|Audit|Supervision) using Security & Compliance PowerShell. SAFE BY DEFAULT: prints the exact cmdlet it WOULD run and makes NO change unless -Commit is passed. Records defaults to a NON-regulatory pilot label; the irreversible regulatory-records label requires the explicit -Regulatory switch. Supervision is always created scoped to the pilot (test) with reviewers you supply. No secrets in code. HOW TO RUN 1) Pilot records label (non-regulatory) — preview then commit: .\CMPFINRA-Configure.ps1 -Control Records -PilotLabel -WhatIf .\CMPFINRA-Configure.ps1 -Control Records -PilotLabel -Commit 2) Audit evidence retention: .\CMPFINRA-Configure.ps1 -Control Audit -PolicyName "Audit Retention – FINRA/SEC Evidence – LongTerm" -RecordTypes AzureActiveDirectory -Duration TenYears -Priority 150 -WhatIf 3) Supervision policy IN TEST (after privacy sign-off): .\CMPFINRA-Configure.ps1 -Control Supervision -PilotScope "FINRA/SEC Pilot – Registered Persons – Stage1" -Reviewers reviewer@contoso.com -WhatIf Requires ExchangeOnlineManagement (Connect-IPPSSession). Interactive modern-auth / MFA admin. EXPECTED RESULTS -WhatIf prints each intended create/remove with no change. -Commit performs it and re-reads the object. PASS = object exists as intended. A -Regulatory label is IRREVERSIBLE — only run under compliance sign-off. Remove non-regulatory objects with -Remove. .NOTES Purview category — FINRA/SEC Compliance Program. High-impact: regulatory records, retention, and supervision are piloted in simulation/test/disabled mode first. Retention durations, supervisory conditions/lexicon, and rule applicability are compliance/records/legal determinations — supplied by you, not invented here. Verify cmdlet/plan availability for your tenant. > [CmdletBinding(DefaultParameterSetName='Records')] param([Parameter(Mandatory)][ValidateSet('Records','Audit','Supervision')][string]$Control,

How to run: 1) Pilot records label (non-regulatory) — preview then commit: .\CMPFINRA-Configure.ps1 -Control Records -PilotLabel -WhatIf .\CMPFINRA-Configure.ps1 -Control Records -PilotLabel -Commit 2) Audit evidence retention: .\CMPFINRA-Configure.ps1 -Control Audit -PolicyName "Audit Retention – FINRA/SEC Evidence – LongTerm" -RecordTypes AzureActiveDirectory -Duration TenYears -Priority 150 -WhatIf 3) Supervision policy IN TEST (after privacy sign-off): .\CMPFINRA-Configure.ps1 -Control Supervision -PilotScope "FINRA/SEC Pilot – Registered Persons – Stage1" -Reviewers reviewer@contoso.com -WhatIf Requires ExchangeOnlineManagement (Connect-IPPSSession). Interactive modern-auth / MFA admin. EXPECTED RESULTS -WhatIf prints each intended create/remove with no change. -Commit performs it and re-reads the object. PASS = object exists as intended. A -Regulatory label is IRREVERSIBLE — only run under compliance sign-off. Remove non-regulatory objects with -Remove. .NOTES Purview category — FINRA/SEC Compliance Program. High-impact: regulatory records, retention, and supervision are piloted in simulation/test/disabled mode first. Retention durations, supervisory conditions/lexicon, and rule applicability are compliance/records/legal determinations — supplied by you, not invented here. Verify cmdlet/plan availability for your tenant. > [CmdletBinding(DefaultParameterSetName='Records')] param([Parameter(Mandatory)][ValidateSet('Records','Audit','Supervision')][string]$Control,

CMPFINRA-Discovery.ps1

Purpose: Reports the current Purview control posture with no changes: compliance licensing present (records / Communication Compliance / Audit Premium-bearing plans), existing retention labels and

policies (flagging records / regulatory-records), Communication Compliance (supervisory) policies, unified audit ingestion state, and existing audit log retention policies. Read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\CMPFINRA-Discovery.ps1 Requires the ExchangeOnlineManagement module (Connect-IPPSSession) and, for the licensing section, Microsoft.Graph with delegated Organization.Read.All / Directory.Read.All. Uses an interactive modern-auth / MFA admin sign-in; no secrets in code. EXPECTED RESULTS A posture summary per control domain. Any capability whose plan/behavior must be confirmed is flagged "verify your licensing/tenant", not asserted. PASS = each in-scope control is present and correctly typed; FAIL = a control is missing or mis-typed (drives the Implementation Guide). .NOTES Purview category — FINRA/SEC Compliance Program. Read-only. Feature availability is licensing-/tenant- dependent and evolving; regulatory/records/legal determinations are deferred to your governance functions. Confirm cmdlet/plan names against your entitlements and current Microsoft documentation. > [CmdletBinding()] param([string]$UserPrincipalName, # optional: admin UPN to pass to Connect-* prompts [switch]$SkipGraphLicensing # skip the Graph licensing section if Graph is unavailable)

How to run: powershell -ExecutionPolicy Bypass -File .\CMPFINRA-Discovery.ps1 Requires the ExchangeOnlineManagement module (Connect-IPPSSession) and, for the licensing section, Microsoft.Graph with delegated Organization.Read.All / Directory.Read.All. Uses an interactive modern-auth / MFA admin sign-in; no secrets in code. EXPECTED RESULTS A posture summary per control domain. Any capability whose plan/behavior must be confirmed is flagged "verify your licensing/tenant", not asserted. PASS = each in-scope control is present and correctly typed; FAIL = a control is missing or mis-typed (drives the Implementation Guide). .NOTES Purview category — FINRA/SEC Compliance Program. Read-only. Feature availability is licensing-/tenant- dependent and evolving; regulatory/records/legal determinations are deferred to your governance functions. Confirm cmdlet/plan names against your entitlements and current Microsoft documentation. > [CmdletBinding()] param([string]$UserPrincipalName, # optional: admin UPN to pass to Connect-* prompts [switch]$SkipGraphLicensing # skip the Graph licensing section if Graph is unavailable)

CMPFINRA-Report.ps1

Purpose: Produces the "Evidence – FINRA/SEC Controls – Binder" export: for each FINRA/SEC control domain (records/regulatory-records retention, communications-store retention, audit evidence, and the communication-supervision policy) it records the implementing Purview object, its key configuration, and a proof reference, cross-referenced to the "Control Map – FINRA/SEC – Purview" register. Read-only — reads current state and writes only a local CSV/JSON evidence file. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\CMPFINRA-Report.ps1 -OutputDir .\evidence Requires the ExchangeOnlineManagement module (Connect-IPPSSession). Interactive modern-auth / MFA admin sign-in; no secrets in code. Optionally pass a control-map CSV via -ControlMapPath to merge your compliance-owned rule→control mapping into the binder. EXPECTED RESULTS A timestamped evidence binder (CSV + JSON) listing each control, its Purview object, configuration, and proof reference. PASS = every in-scope control resolves to a present, correctly-typed object with a proof reference; FAIL = a control with no object or no evidence (surfaces the gap to fill before an exam). Adequacy of retention/scope and rule fit is NOT asserted — that is compliance's. .NOTES Purview category — FINRA/SEC Compliance Program. Read-only (emits a local evidence file only). A control's presence is proven here; whether it SATISFIES a FINRA/SEC rule is a compliance/records/legal determination. Verify cmdlet/plan names against your entitlements and current Microsoft documentation. > [CmdletBinding()] param([string]$OutputDir = '.\evidence', [string]$ControlMapPath, # optional: compliance-owned rule→control CSV to merge [string]$RegulatoryLabel = 'Records – FINRA/SEC Regulated – Regulatory',

[string]$PilotLabelMatch = 'FINRA/SEC', # substring identifying pilot/records labels [string]$CommsRetention = 'Retention – FINRA/SEC Comms Store – Immutable', [string]$PublishPolicy = 'Retention – FINRA/SEC Records – Publish', [string]$AuditPolicy = 'Audit Retention – FINRA/SEC Evidence – LongTerm', [string]$Supervision = 'Supervision – Registered Persons Comms – Test')

How to run: powershell -ExecutionPolicy Bypass -File .\CMPFINRA-Report.ps1 -OutputDir .\evidence Requires the ExchangeOnlineManagement module (Connect-IPPSSession). Interactive modern-auth / MFA admin sign-in; no secrets in code. Optionally pass a control-map CSV via -ControlMapPath to merge your compliance-owned rule→control mapping into the binder. EXPECTED RESULTS A timestamped evidence binder (CSV + JSON) listing each control, its Purview object, configuration, and proof reference. PASS = every in-scope control resolves to a present, correctly-typed object with a proof reference; FAIL = a control with no object or no evidence (surfaces the gap to fill before an exam). Adequacy of retention/scope and rule fit is NOT asserted — that is compliance's. .NOTES Purview category — FINRA/SEC Compliance Program. Read-only (emits a local evidence file only). A control's presence is proven here; whether it SATISFIES a FINRA/SEC rule is a compliance/records/legal determination. Verify cmdlet/plan names against your entitlements and current Microsoft documentation. > [CmdletBinding()] param([string]$OutputDir = '.\evidence', [string]$ControlMapPath, # optional: compliance-owned rule→control CSV to merge [string]$RegulatoryLabel = 'Records – FINRA/SEC Regulated – Regulatory', [string]$PilotLabelMatch = 'FINRA/SEC', # substring identifying pilot/records labels [string]$CommsRetention = 'Retention – FINRA/SEC Comms Store – Immutable', [string]$PublishPolicy = 'Retention – FINRA/SEC Records – Publish', [string]$AuditPolicy = 'Audit Retention – FINRA/SEC Evidence – LongTerm', [string]$Supervision = 'Supervision – Registered Persons Comms – Test')

CMPFINRA-Scope.ps1

Purpose: Enumerates the intended in-scope population and confirms toolchain health with no changes: members of the covered-persons group, the mailboxes/sites in scope, the compliance role groups it can see (for reviewer-separation review), and which endpoints (S&C PowerShell / Graph) are reachable. Use before configuring so the pilot scope is grounded in real objects. Read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\CMPFINRA-Scope.ps1 -CoveredPersonsGroup "Registered Persons" Requires ExchangeOnlineManagement (Connect-IPPSSession) and, for group membership, Microsoft.Graph with delegated Group.Read.All / User.Read.All. Interactive modern-auth / MFA admin; no secrets. EXPECTED RESULTS A scope summary: group member count, sample in-scope mailboxes, visible role groups, and endpoint reachability. PASS = the covered-persons group resolves and both endpoints are reachable; FAIL = group not found or an endpoint unreachable (resolve before configuring). .NOTES Purview category — FINRA/SEC Compliance Program. Read-only. In-scope population is a compliance determination; this only enumerates what you name. Confirm cmdlet/role names against your tenant. > [CmdletBinding()] param([string]$CoveredPersonsGroup, # display name of the group of covered/registered persons (optional) [string]$UserPrincipalName, [switch]$SkipGraph)

How to run: powershell -ExecutionPolicy Bypass -File .\CMPFINRA-Scope.ps1 -CoveredPersonsGroup "Registered Persons" Requires ExchangeOnlineManagement (Connect-IPPSSession) and, for group membership, Microsoft.Graph with delegated Group.Read.All / User.Read.All. Interactive modern-auth / MFA admin; no secrets. EXPECTED RESULTS A scope summary: group member count, sample in-scope mailboxes, visible role groups, and endpoint reachability. PASS = the covered-persons group resolves and both endpoints are reachable; FAIL = group not found or an endpoint unreachable (resolve before configuring). .NOTES Purview category — FINRA/SEC Compliance Program. Read-only. In-scope population is a compliance determination; this only enumerates what you name. Confirm cmdlet/role names against your tenant. > [CmdletBinding()] param([string]$CoveredPersonsGroup, # display name of

the group of covered/registered persons (optional) [string]$UserPrincipalName, [switch]$SkipGraph)

CMPFINRA-Validate.ps1

Purpose: Scores the program across the three control domains with no changes: records/regulatory-records label present and correctly typed, comms-store retention scoped, unified audit on with the evidence-retention policy present, and a supervision policy present IN TEST. Emits a PASS/FAIL per gate mirroring the Testing Guide. Read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\CMPFINRA-Validate.ps1 Requires ExchangeOnlineManagement (Connect-IPPSSession). Interactive modern-auth / MFA admin; no secrets. For audit ingestion state it also uses Connect-ExchangeOnline where available. EXPECTED RESULTS A scorecard: each gate GREEN (pass) or RED (fail) with the remediation pointer. PASS overall = every in-scope gate green for the pilot scope. Determination-level adequacy (retention, scope, rule fit) is NOT scored here — that is compliance/records/legal's. .NOTES Purview category — FINRA/SEC Compliance Program. Read-only. Proves the technical control works and is present; does not certify regulatory compliance. Verify cmdlet/plan names for your tenant. > [CmdletBinding()] param([string]$RegulatoryLabel = 'Records – FINRA/SEC Regulated – Regulatory', [string]$CommsRetention = 'Retention – FINRA/SEC Comms Store – Immutable', [string]$AuditPolicy = 'Audit Retention – FINRA/SEC Evidence – LongTerm', [string]$SupervisionPolicy = 'Supervision – Registered Persons Comms – Test', [switch]$AllowPilotLabel # accept a non-regulatory pilot records label as a pass for the records gate (pre sign-off))

How to run: powershell -ExecutionPolicy Bypass -File .\CMPFINRA-Validate.ps1 Requires ExchangeOnlineManagement (Connect-IPPSSession). Interactive modern-auth / MFA admin; no secrets. For audit ingestion state it also uses Connect-ExchangeOnline where available. EXPECTED RESULTS A scorecard: each gate GREEN (pass) or RED (fail) with the remediation pointer. PASS overall = every in-scope gate green for the pilot scope. Determination-level adequacy (retention, scope, rule fit) is NOT scored here — that is compliance/records/legal's. .NOTES Purview category — FINRA/SEC Compliance Program. Read-only. Proves the technical control works and is present; does not certify regulatory compliance. Verify cmdlet/plan names for your tenant. > [CmdletBinding()] param([string]$RegulatoryLabel = 'Records – FINRA/SEC Regulated – Regulatory', [string]$CommsRetention = 'Retention – FINRA/SEC Comms Store – Immutable', [string]$AuditPolicy = 'Audit Retention – FINRA/SEC Evidence – LongTerm', [string]$SupervisionPolicy = 'Supervision – Registered Persons Comms – Test', [switch]$AllowPilotLabel # accept a non-regulatory pilot records label as a pass for the records gate (pre sign-off))